



SÃO
PAULO
TECH
SCHOOL

LGPD – Lei Geral de Proteção de Dados

Aula

TÓPICOS DA AULA

- Vamos falar sobre Leis?
- Falando sobre Privacidade.
- A LGPD e suas origens.
- Conceitos utilizados na LGPD.
- Quem Fiscaliza?
- LGPD na Prática.
- Conclusões.

Vamos Pesquisar???

- Quando a LGPD entrou em vigor?
- Qual foi a base dela (onde ela foi inspirada)?
- Quais são as suas diretrizes e/ou motivadores?
- Quais são os motivadores?

Pesquisar em grupo de P.I.

Não é necessário criar PPT, é uma pesquisa para discutirmos.

- Mão a obra

Privacidade ???

Eles sabem mais sobre seus clientes, do que nós podemos imaginar!!!

LinkedIn



mercado
livre

amazon

NETFLIX

Google

YouTube



tinder

Todas as marcas aqui representadas são registradas e de propriedade dos seus titulares legais.

A LGPD e suas Origens



A Lei Geral de Proteção de Dados Pessoais (LGPD) estabelece diretrizes importantes e obrigatórias para a **coleta, processamento e armazenamento de dados pessoais**.

Ela foi inspirada na GDPR (General Data Protection Regulation), que entrou em vigência em 2018 na União Europeia, trazendo grandes impactos para empresas e consumidores.

No Brasil, a LGPD (Lei nº 13.709, de 14/8/2018) entrou em vigor em 18 de setembro de 2020, representando um passo importante para o Brasil. Com isso, passamos a fazer parte de um grupo de países que contam com uma legislação específica para a proteção de dados dos seus cidadãos.

A LGPD e seus Objetivos

A Legislação se fundamenta em diversos valores e tem como principais objetivos:



- Respeito à **privacidade**, ao assegurar os direitos fundamentais de **inviolabilidade** da intimidade, da honra, da imagem e da vida privada;



- A **autodeterminação informativa**, ao expressar o direito do cidadão ao controle, e assim, à proteção de seus **dados pessoais** e íntimos;



- A **liberdade de expressão**, de informação, de comunicação e de opinião, que são direitos previstos na Constituição brasileira;



- O **desenvolvimento econômico e tecnológico** e a inovação, a partir da criação de um cenário de **segurança jurídica** em todo o país;



- A livre iniciativa, a livre concorrência e a **defesa do consumidor**, por meio de **regras claras** e válidas para todo o setor privado;



- Os **direitos humanos**, o livre desenvolvimento da personalidade, a dignidade e o exercício da **cidadania** pelas pessoas.

A LGPD e sua Importância

Porque a LGPD é tão importante neste momento?

- Nunca se **coletou** tantos dados (e isto só tende a aumentar!)
- Dados significam conhecimento e **poder** (para o bem ou para o mal!).
- Dados são livremente **compartilhados** (já postou hoje?)
- **Vazamentos** de dados podem destruir reputações (isto é muito grave!)
- Diversos escândalos sobre **utilização indevida** de dados (Cambridge Analytica-Facebook)
- Potenciais ações de cunho **discriminatório** com bases em dados sensíveis (intencional ou não intencional – enviesamento de algoritmos)
- Promove **Segurança Jurídica** para as relações de negócio e sociais.
- A regulação da proteção de dados é uma **tendência mundial** (e se não for seguida pode prejudicar relações comerciais, diplomáticas, etc)

Conceitos utilizados na LGPD

Vamos entender a conceituação dos dados pela LGPD?

- Dados PESSOAIS

- ✓ **Qualquer** informação **relacionada** a uma pessoa natural IDENTIFICADA ou IDENTIFICÁVEL. Ex. CPF, Nome, Endereço, Foto.
- ✓ Dado **SENSÍVEL** é um tipo de dado pessoal cujo tratamento ou utilização pode ensejar alguma forma de **discriminação** do seu titular, por se referirem, por exemplo, à raça, cor da pele, orientação sexual, convicções religiosas, filosóficas, morais, opiniões políticas, etc.

- Dados PSEUDO-ANONIMIZADOS

São os dados que passaram por **tratamento** em que ele perde a **possibilidade de associação**, direta ou indireta, a um indivíduo, senão pelo uso de **informação adicional** mantida separadamente pelo controlador em ambiente controlado e seguro.

Conceitos utilizados na LGPD

Vamos entender a conceituação dos dados pela LGPD?

- Dados ANONIMIZADOS

- ✓ Dado relativo a titular que **não possa ser identificado**, considerando a utilização de meios técnicos razoáveis e disponíveis na ocasião de seu tratamento. **Ex. Dados descaracterizados como XXX.XXX.XXX-96.**

Principais técnicas de Anonimização de dados

Supressão de dados – Excluir o nome e CPF do titular do dado.

Ex. Eliminar informações de uma tabela no banco de dados.

Encobrimento de caracteres – Encobrir parcial ou totalmente um dado

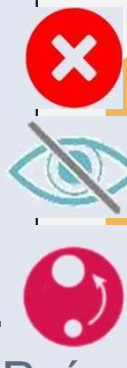
Ex. Ao invés do telefone completo trocar por (41) 4583-XXXX.

Generalização – Substituir dados precisos por categorias genéricas

Ex. Substituir idade por faixa etária, substituir CEP por Cidade ou País.



É importante ter cuidado para não adotar categorias muito “estreitas”, que ainda facilitem a identificação do Titular.



Pessoa IDENTIFICADA e PESSOA IDENTIFICÁVEL – Como Assim?

- Pessoa IDENTIFICADA
 - ✓ Quando o indivíduo pode ser identificado diretamente e de forma inequívoca por algum dado seu, sem a necessidade de cruzamento de informações. Ex. CPF, Nome Completo, Foto.
- Pessoa IDENTIFICÁVEL
 - ✓ Quando o indivíduo pode ser identificado com uma probabilidade razoável de acerto, através de processos, conjugação e derivação de dados. Ex. Primeiro nome + Endereço + Data de Nascimento ou Dado Criptografado + Chave Criptográfica.

Um pouco mais sobre o conceito de PESSOA IDENTIFICÁVEL...

- Para determinar se um indivíduo é “identificável” devem ser considerados os fatos associados, contexto da coleta, tipo do dado, finalidade ou intenção do uso, além de fatores objetivos que podem ser decisivos na identificação, tais como o tempo necessário, o custo e a tecnologia disponíveis no momento.

Alguns casos para reflexão:

- Autoridade de trânsito fotografa veículos em excesso de velocidade e repassa tais dados a outro órgão para que seja feita a emissão da multa;
- Empresa de transporte por aplicativo recolhe dados de posicionamento e localização dos veículos prestadores de serviço;
- Empresa de delivery de comida descobre que a Pizza é o alimento predileto nas noites de sábado;
- Empresa de e-commerce se recusa a entregar pedido em determinado CEP.

Tratamento de dados.

- São considerados tipos de **Tratamento de Dados Pessoais**:

- ✓ Coleta, Produção e Recepção;
- ✓ Classificação, Utilização e Acesso;
- ✓ Reprodução, Transmissão e Distribuição;
- ✓ Processamento, Arquivamento, Armazenamento;
- ✓ Eliminação, Avaliação e Controle,
- ✓ Modificação, Comunicação, Transferência;
- ✓ Difusão e Extração

Ou seja:

- **Praticamente tudo** o que se fizer com **Dados Pessoais** estará sujeito aos termos regulamentados pela Lei Geral de Proteção de Dados.

Exceto...

Exceções para as regras de Tratamento de Dados previstas na LGPD.

- **Não** estão sob a cobertura da LGPD:
 - ✓ Realizado por **pessoa natural** para **fins exclusivamente particulares** e não econômicos;
 - ✓ Realizado para **fins** exclusivamente **Jornalísticos, Artísticos e Acadêmicos**;
 - ✓ Realizado para **fins** exclusivos de **Segurança Pública, Defesa Nacional** ou de Estado,
 - ✓ Atividades de **investigação e repressão de infrações penais**;
 - ✓ Tratamento de dados provenientes de **fora do território nacional**.

Porém:

- Cada uma destas exceções tem suas particularidades detalhadas em legislação complementar a serem consideradas caso a caso.

Papéis e Responsabilidades relacionados aos Dados Pessoais

- **Titular**

- ✓ **Pessoa natural** a quem se referem os **dados pessoais** que são objeto de tratamento.

- **Controlador:**

- ✓ Pessoa natural ou jurídica, de direito público ou privado, a quem competem as **decisões** referentes ao **tratamento** de dados pessoais.

- **Operador**

- ✓ Pessoa natural ou jurídica, de direito público ou privado, que realiza o **tratamento** de **dados pessoais** em nome do Controlador;
- ✓ Deve manter os **registros** de todas as **operações realizadas** com os dados.

- **Encarregado**

- ✓ Pessoa natural, indicada pelo Controlador, que atua como **canal de comunicação** entre o Controlador e os Titulares e a Autoridade Nacional;
- ✓ Responde legalmente pelo **cumprimento** das **regras** previstas na Lei;
- ✓ Acolhe **reclamações** de Titulares e presta **esclarecimentos** necessários;
- ✓ Divulga ocorrências e **vazamentos** que **comprometam** Dados Pessoais.

Atividade – Casos para Discussão

Vazamento de compra de remédio controlado.

- Consumidor de medicamento controlado foi reconhecido por um dos atendentes de uma farmácia. Este tirou uma foto do receituário médico e encaminhou no grupo do WhatsApp, no qual se encontravam mais pessoas que conheciam o consumidor.

Vazamento de atestado médico de um funcionário

- Uma impressora utilizada pelo setor de RH era compartilhada com demais setores da empresa. O atestado médico de um dos colaboradores, no qual constava que este era portador do vírus HIV, foi visto por um de seus colegas de trabalho e a informação foi vazada dentro e fora da empresa.

Construtora compartilha dados pessoais de clientes.

- Construtora repassou dados pessoais de clientes sem autorização. Um cliente que comprou um imóvel desta construtora começou a ser importunado por telefone, WhatsApp e e-mail por diversas outras empresas.



Atividade – Casos para Discussão

Dona Maria do Bolo.

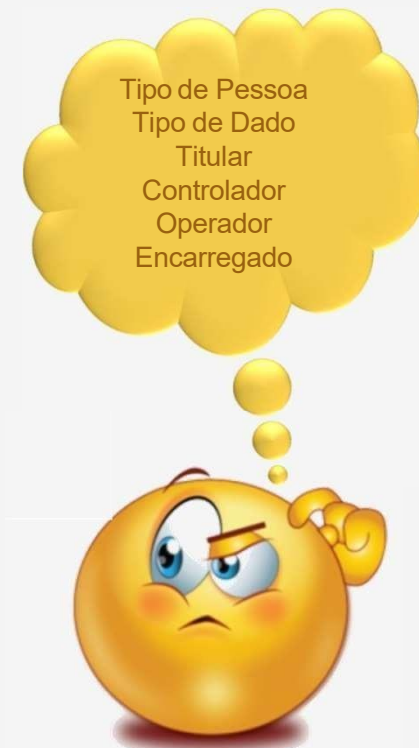
- Compartilha seus contatos de whatsapp com uma empresa de delivery.

Síndico de condomínio

- . Compartilha dados pessoais de condôminos.

Para a turma da aula: Cite um caso...

Por que ligam pra você de plano de saúde?



Vamos Pesquisar....

ANPD - Agência Nacional de Proteção de Dados

- O que é?
- Qual é a atuação?
- Para quem?

DPO - Data Protection Officer

- O que é?
- Qual é a atuação
- Quais as responsabilidades?
- Para quem?

Quem Fiscaliza?

Quem garante o cumprimento da LGPD?

- **Autoridade Nacional de Proteção de Dados**

- ✓ Órgão da Administração Pública Federal, integrante da Presidência da República, composta por unidades administrativas e técnicas;
- ✓ Possui **autonomia** técnica assegurada pela LGPD;
- ✓ Suas principais atribuições são:
 - **Fiscalizar e aplicar sanções** na hipótese de tratamento de dados realizado em descumprimento à legislação, mediante processo administrativo que assegure o contraditório, a ampla defesa e o direito de recurso;
 - **Comunicar** às autoridades competentes as **infrações** penais das quais tiver conhecimento;
 - **Comunicar** aos órgãos de controle interno o **descumprimento** do disposto na LGPD **praticado por órgãos e entidades da administração pública federal**;
 - **Zelar** pela proteção de dados pessoais;
 - **Editar** normas e **procedimentos** sobre a proteção de dados pessoais;

A Lei Geral de Proteção de dados – LGPD tem relação Segurança de Dados

DPO - DATA PROTECTION OFFICER

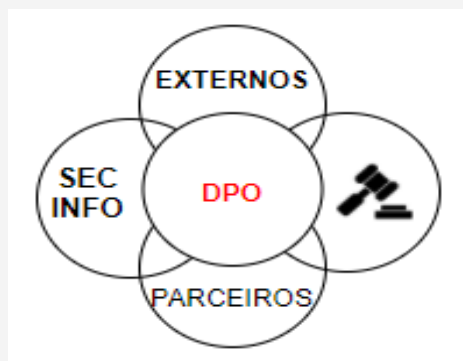


Lei 13.709/2018 –Lei geral de Proteção de dados

dispõe sobre o tratamento de dados pessoais, inclusive nos meios digitais, por pessoa natural ou por pessoa jurídica de direito público ou privado, com o objetivo de proteger os direitos fundamentais de liberdade e de privacidade e o livre desenvolvimento da personalidade da pessoa natural.

Conhecido também como Encarregado pelo Tratamento de Dados Pessoais, é o principal responsável por manter a conformidade das organizações com a LGPD, sendo considerado o verdadeiro guardião do Programa de Governança em Privacidade

DPO – Data Protection Officer



- DPO - especialista independente responsável por supervisionar a estratégia de proteção de dados e a implementação das políticas de privacidade dentro de uma organização

- Atua como ponto de contato entre a organização, os titulares dos dados e a Autoridade Nacional de Proteção de Dados (ANPD).

Importância do DPO:

- Garante a conformidade legal e regulatória.
- Aumenta a confiança dos clientes e parceiros.
- Mitiga riscos de sanções e danos à reputação.
- Fomenta uma cultura de proteção de dados dentro da organização.
- Facilita a comunicação com os titulares dos dados e a ANPD.

Quem precisa de um DPO?

- A LGPD estabelece critérios para a obrigatoriedade da designação de um DPO, considerando o porte da organização, o volume e a sensibilidade dos dados tratados.
- Mesmo que não seja obrigatório, designar um DPO demonstra o compromisso da organização com a proteção de dados.

Ok, mas onde tudo isto impacta no meu projeto ou sistema?

- Na prática, você que é DEV ou PO, deve se preocupar com:
 - ✓ Prover funcionalidade onde o Titular possa visualizar e **alterar livremente** seus Dados Pessoais;
 - ✓ Permitir ao Titular a **eliminação** parcial ou completa dos seus Dados Pessoais;
 - ✓ Permitir ao Titular **portabilidade** dos Dados Pessoais mediante consentimento;
 - ✓ Implantar **atualização** de dados em **cadeia**;
 - ✓ Criar canais onde o Titular possa **obter informações** sobre o uso dos seus dados;
 - ✓ Criar **Termos de Aceite** sem **Vícios de Consentimento**;
 - ✓ Implantar **registros** (logs) de **toda ação** realizada sobre Dados Pessoais;
 - ✓ Prover meios de **rastreabilidade** sobre a divulgação, compartilhamento ou transmissão de dados pessoais;
 - ✓ Elaborar Plano de Ação e Comunicação a respeito de **vazamentos** de dados;
 - ✓ Prover mecanismos de **segurança digital** para os ambientes de processamento e armazenamento de Dados Pessoais;

Concluindo

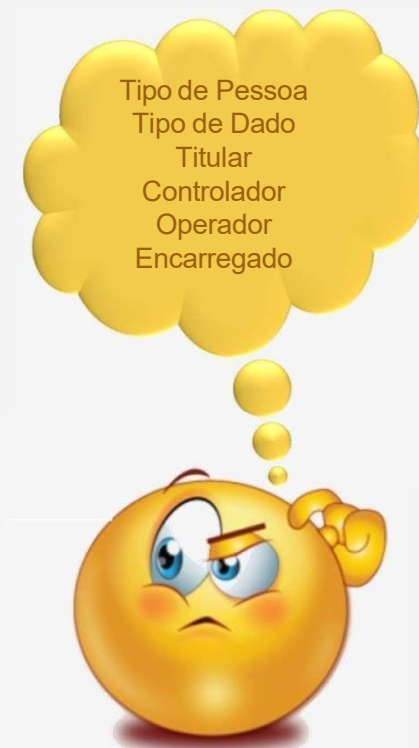
- A construção de novos Sistemas ou os processos de adequação de Sistemas Legados à LGPD é uma atividade multidisciplinar;
- Engloba uma série de atores técnicos, administrativos e jurídicos que, em conjunto, irão discutir requisitos técnicos e funcionais, processos administrativos e aspectos jurídicos relacionados de forma a alcançar a melhor aderência ao que dispõe a Lei;
- Cada empresa deve realizar uma autoanálise e se situar quanto à distância em que se encontra da conformidade e encarar a mudança, já que não fazê-la é estar em risco iminente;
- Apoiar-se em Normas Técnicas (Ex. ISO [27.000](#), [29.100](#), [29.134](#), [29.151](#), [29.184](#)) que versam sobre Segurança e Compliance normalmente as aproximam da conformidade;
- O apoio de uma Consultoria especializada pode facilitar e acelerar muito o processo de adequação.



Descrever para o seu projeto de P.I.

- Quais tipos de Pessoas são contempladas no projeto
- Quais dados necessitam de cuidado
- Quais tratamentos deveriam ser implementados?

Criar um PDF e “upar” um por grupo.





Case: A Instabilidade na Americanas e a Tempestade de Dados: Uma Análise à Luz da LGPD

Em fevereiro de 2023, a varejista Americanas S.A. enfrentou uma grave instabilidade em seus sistemas que resultou na exposição de dados de um número significativo de seus clientes. As informações que se tornaram acessíveis incluíam nomes completos, CPFs, endereços de e-mail, números de telefone e, em alguns casos, dados de histórico de compras. A empresa inicialmente atribuiu o problema a uma "instabilidade" e negou ter sofrido um ataque cibernético. No entanto, a extensão da exposição dos dados gerou grande preocupação entre os consumidores e órgãos de proteção de dados.

Case: A Instabilidade na Americanas e a Tempestade de Dados: Uma Análise à Luz da LGPD

Analisar a situação sob a perspectiva da Lei Geral de Proteção de Dados (LGPD) e propor soluções para os seguintes pontos:

- **Identificação das possíveis falhas de segurança:** Quais mecanismos de segurança da informação poderiam ter falhado ou se mostrado insuficientes para evitar a exposição dos dados, mesmo não sendo um ataque externo direto? Considerar medidas preventivas e reativas.
- **Análise da comunicação da Americanas:** Avaliar a postura e a comunicação da empresa em relação ao incidente. A empresa cumpriu com as obrigações de notificação à Autoridade Nacional de Proteção de Dados (ANPD) e aos titulares dos dados afetados de forma adequada e transparente? Quais foram os impactos dessa comunicação na percepção pública?

Case: A Instabilidade na Americanas e a Tempestade de Dados: Uma Análise à Luz da LGPD

- **Responsabilidade da Americanas sob a LGPD:** Discutir a responsabilidade da Americanas em relação à segurança dos dados de seus clientes, mesmo que a causa primária não tenha sido um ataque malicioso. Quais artigos da LGPD podem ser aplicados ao caso? Considerar os princípios da prevenção, segurança e responsabilização.
- **Direitos dos titulares de dados afetados:** Quais são os direitos dos clientes da Americanas que tiveram seus dados expostos à luz da LGPD? Que medidas eles podem tomar para se proteger e buscar reparação por eventuais danos?

Case: A Instabilidade na Americanas e a Tempestade de Dados: Uma Análise à Luz da LGPD

- **Propostas de soluções e medidas preventivas:** Que medidas a Americanas (ou qualquer outra empresa que lida com dados pessoais em larga escala) deveria implementar para prevenir incidentes semelhantes no futuro? Considerar tanto aspectos técnicos (segurança cibernética, criptografia, anonimização) quanto aspectos organizacionais (políticas de privacidade, treinamento de funcionários, governança de dados).
- **O papel da ANPD:** Qual o papel da Autoridade Nacional de Proteção de Dados (ANPD) neste caso? Que tipo de investigação e sanções poderiam ser aplicadas, caso se constate descumprimento da LGPD?

Case: A Instabilidade na Americanas e a Tempestade de Dados: Uma Análise à Luz da LGPD

- Pesquisar a respeito do case
- A atividade pode ser realizada em grupo de no máximo 6 alunos
- Apenas 1 aluno do grupo “upa” a sugestão do grupo de como evitar novos vazamentos e o que poderia ter causado o incidente, formato PDF
- Não esquecer de colocar RA e Nome de todos os participantes

Agradeço
a sua atenção!



SÃO
PAULO
TECH
SCHOOL